THE WEBSITE PRIVACY & COMPLIANCE PLAYBOOK

A practical implementation checklist for Indian website owners

For founders, freelancers, agencies, creators and online businesses

Start here: what this guide covers

This playbook turns common website privacy and online-business questions into an actionable audit. It covers privacy notices, consent, contact and grievance channels, cookies and tracking, website terms, e-commerce disclosures, children's data, and security/breach readiness.

Important legal note: This is general educational information, not legal advice or a guarantee of compliance. Requirements depend on your business model, data flows, audience, sector and the provisions actually in force. Have an Indian lawyer or privacy professional review your final setup, especially for sensitive or high-volume processing.

DPDP Act timeline: don't confuse enactment with commencement

India's Digital Personal Data Protection Act, 2023 and the Digital Personal Data Protection Rules, 2025 use a phased commencement schedule. The notified schedule places many substantive duties—including the core notice, consent, security and individual-rights framework—18 months after publication of the Rules on 13 November 2025, i.e. 13 May 2027. Certain provisions commenced earlier, and the Consent Manager provisions are on a separate one-year timeline. Check the latest Gazette notifications and corrigenda before relying on a date.

· Do not say every website must use a cookie banner in every situation. Assess what data is collected, why, by whom and under which legal basis.

· A tracking pixel is not automatically illegal. The configuration, personal data involved, disclosures, consent requirements and other applicable laws matter.

· The often-quoted ₹250 crore figure is the maximum penalty for specified contraventions under the Act, not an automatic fine for having a pixel or a missing page.

The 8-point website audit

1. Publish a clear privacy notice / privacy policy

Explain in plain language what personal data you collect, why you collect it, how it is used, who receives it, how long it is retained, how people can exercise rights or raise complaints, and how to contact you.

· Inventory every collection point: contact form, checkout, newsletter, account sign-up, chat widget, analytics, CRM and support inbox.

· Name the purposes specifically (e.g., respond to enquiries, fulfil orders, send opted-in marketing, prevent fraud). Avoid vague wording such as “for business purposes”.

· List relevant categories of service providers/recipients where appropriate, and explain retention criteria.

· Put a visible Privacy Policy link in the website footer and near relevant forms. Keep the policy dated and review it when tools or purposes change.

2. Collect and record valid consent where required

Consent should be informed, specific, clear and affirmative where consent is the applicable basis. Do not treat silence, pre-ticked boxes or continued browsing as universal consent.

· Use unticked checkboxes for optional marketing where appropriate; keep the service request separate from optional promotions.

· Tell people what they are agreeing to, before collection. Link to the privacy notice.

· Store a consent record: timestamp, wording/version shown, purpose, source/page and action taken.

· Provide a practical way to withdraw consent as easily as it was given, where consent is the basis. Stop the relevant processing when required.

· Do not assume one checkbox covers unrelated purposes or every third-party tool.

3. Provide a working contact and grievance route

People should be able to contact the business about data handling. DPDP requirements include a contact route for questions and grievance redressal when the relevant provisions apply. Separate sectoral or e-commerce rules may impose additional duties.

· Publish a monitored email address or contact form for privacy questions and complaints.

· Assign an internal owner, set a response workflow and maintain a complaint log.

· For e-commerce entities covered by the Consumer Protection (E-Commerce) Rules, check the applicable Grievance Officer and display requirements; those rules include specified response timelines.

· Test the route monthly and ensure submissions reach a real person or monitored queue.

4. Audit cookies, pixels, analytics and third-party scripts

Make a complete list of technologies that collect or share visitor data. Disclose relevant tracking in a way that matches actual behaviour and applicable requirements.

· Check Google Analytics, Meta Pixel, LinkedIn Insight Tag, ad pixels, session replay, heatmaps, chat widgets, embedded videos, CAPTCHAs and tag managers.

· For each tool, record purpose, data collected, provider, trigger conditions, data sharing and retention settings.

· Configure consent controls where required; optional technologies should not fire before the relevant choice where the law/policy requires prior consent.

· Offer clear choices and a way to revisit them. Do not label a button “Reject” if it merely closes the banner.

· Remove unused tags and test with browser developer tools or a consent-audit tool.

5. Add suitable website terms and service policies

Terms should reflect what the site actually offers. They are not a substitute for a privacy notice and cannot override statutory consumer rights.

· For a service business: describe scope, payment, cancellations, deliverables, IP, acceptable use, support and dispute process as relevant.

· For a store: make delivery, cancellation, returns/refunds, warranties, payment and complaint procedures easy to find.

· Avoid unfair, misleading or one-sided clauses. Get legal review for high-value, subscription, SaaS or regulated services.

· Link terms at relevant points, such as checkout or account creation, and retain the version accepted where useful.

6. If you sell online, check e-commerce disclosures

The Consumer Protection (E-Commerce) Rules, 2020 may apply to goods and services sold online. Exact obligations depend on the entity/model and subsequent amendments.

· Display accurate business identity and contact information as required for your model.

· Make total price, payment methods, delivery/shipping, cancellation, returns/refunds, warranty/guarantee and relevant seller details clear before purchase.

· Provide an accessible complaint mechanism and check whether a Grievance Officer must be appointed and displayed.

· Do not assume these e-commerce obligations apply identically to every brochure website or lead-generation page; assess applicability.

7. Take extra care with children’s data

The DPDP framework has special protections for children, including parental-consent requirements and restrictions, subject to the Act, Rules, exemptions and applicable commencement dates.

· Decide whether the service is directed at children or is likely to process children’s personal data.

· Do not collect a child’s date of birth or identity documents “just in case”; collect only what is necessary.

· Where applicable, implement a legally appropriate method to obtain and verify parental consent before processing.

· Review targeted advertising, tracking and behavioural monitoring involving children, as restrictions may apply.

· Do not copy an age-gate or parental-consent flow from another site without checking its legal and technical suitability.

8. Secure personal data and prepare for incidents

Use reasonable technical and organisational safeguards appropriate to the risk. Prepare a documented process to detect, contain, investigate and report breaches as required by the applicable framework.

· Use HTTPS throughout; keep CMS, plugins, themes and server software patched.

· Enable MFA for admin, hosting, domain, email, analytics and payment accounts. Use unique passwords and least-privilege access.

· Limit form fields; avoid collecting sensitive information unless genuinely needed. Restrict access to submissions and CRM records.

· Set backups, test restoration, protect exports, and define retention/deletion rules for forms, CRM and mailing lists.

· Create an incident plan: who investigates, who makes legal decisions, how evidence is preserved, and who communicates with affected people/regulators when required.

· Check vendor contracts and security settings for hosting, CRM, email marketing, analytics and form providers.

Implementation guide: a 7-day starter plan

Day 1 — Map data: List all forms, tools, pixels, plugins, databases and people who can access personal data. Test the site as a new visitor.

Day 2 — Fix the notice: Draft or update the privacy notice to match the real data flows. Add links in the footer and near collection points.

Day 3 — Fix consent and tracking: Separate optional marketing from essential service communications. Audit tag firing and implement a suitable preference flow where required.

Day 4 — Review terms and commerce: Update service terms and, if selling online, review pricing, delivery, refund/cancellation and grievance disclosures.

Day 5 — Security basics: Turn on MFA, patch software, remove unused accounts, review permissions and test backups.

Day 6 — Rights and complaints: Create an inbox/workflow for privacy queries, correction/deletion requests and complaints; assign an owner and log outcomes.

Day 7 — Test and document: Test desktop/mobile forms, consent choices, unsubscribe, links, data deletion, and incident escalation. Record gaps, owners and target dates.

Copy-ready examples (adapt before publishing)

A. Short form notice

“We’ll use the information you submit to respond to your enquiry and provide the service you request. We may share it with service providers who help us operate this website, subject to appropriate safeguards. See our Privacy Policy for details about use, retention, your choices and how to contact us.”

Use this only as a starting point. Add the actual purposes, recipients, retention details and required rights/contact information for your business.

B. Optional marketing choice

☐ “I’d like to receive product updates and marketing emails. I can unsubscribe at any time.”

Keep optional marketing separate from the action needed to answer an enquiry or fulfil an order.

C. Tracking inventory template

Tool / vendor	Purpose	Data / events	When it fires	Owner / action

Launch checklist

- ☐ I know what personal data each form and tool collects.
- ☐ My privacy notice matches the actual site and business.
- ☐ Optional marketing consent is separate and recorded where needed.
- ☐ Cookies/pixels have been audited and behave as intended.
- ☐ Privacy and complaint contact routes are monitored.
- ☐ Terms and e-commerce disclosures are appropriate to my business model.
- ☐ Children’s-data risks have been assessed if relevant.
- ☐ MFA, updates, access controls, backups and an incident plan are in place.
- ☐ I have checked the latest official commencement notifications and applicable sector-specific laws.
- ☐ I have scheduled a review whenever I add a new form, pixel, vendor or data use.